



Government
Digital Service



Department for
Science, Innovation
& Technology

Using Threat Dragon for Secure By Design

Contents

Contents	2
Background	3
Threat Dragon and the Secure by Design Lifecycle	4
3. Design: Understanding a service and its architecture	4
4. Threat Discovery and Threat Modelling	5
5. Connecting Threats to Security Controls	6
6. Supporting Risk Management	7
7. Security Architecture Reviews	7
8. Security Testing and Assurance	8
9. Evidence, Governance and Auditability	9
More information	9

Background

Secure by Design is the UK Government approach to securing digital delivery, ensuring that security is considered throughout the lifecycle of a digital service, rather than being treated as a final-stage compliance or testing activity. It requires projects to understand their security risks, design appropriate controls, and continually reassess those controls as the service evolves.

A key activity within Secure by Design is **threat modelling**. The UK Government's Secure by Design guidance describes threat modelling as the process of identifying likely threat events, understanding vulnerabilities and attack surfaces, and using this information to build appropriate security controls into a service. It recommends performing threat modelling during service design and build, and repeating it when security-relevant changes or new threats emerge.

OWASP Threat Dragon is an open-source threat-modelling tool that is particularly well suited to this activity. It provides a graphical environment for creating data-flow diagrams, recording threats and mitigations, and maintaining the relationship between the system architecture and its security risks. It supports methodologies including STRIDE, LINDDUN, CIA, DIE and PLOT4ai, and can produce reports from the resulting threat model.

Threat Dragon should not be regarded as a complete Secure by Design solution in itself. Rather, it is a practical tool that supports several Secure by Design activities, particularly threat modelling, architecture analysis, security requirements, risk management, security assurance, and maintaining an auditable record of security decisions.

Threat Dragon and the Secure by Design Lifecycle

A useful way of incorporating Threat Dragon into a Secure by Design project is to treat the threat model as a **living security artefact**.

At the beginning of a project, your delivery team creates a high-level model of the proposed service. As requirements and architecture become more detailed, the model can expand. Identify threats against components and dataflows; then you can mitigate, and feed this - and any residual risks - into your organisation's risk-management and delivery processes.

The model should then be revisited at significant architectural changes, such as introducing a new API, connecting a new external service, changing authentication arrangements, introducing a new data store, or changing the classification or sensitivity of information.

This approach aligns closely with the Secure By Design that [threat modelling should take place during design and build](#) - and be repeated when significant security implications arise.

The important principle is that a threat modelling tool, such as Threat Dragon, should support the project's security process rather than become a separate documentation exercise.

3. Design: Understanding a service and its architecture

One of the earliest Secure by Design activities is [establishing what will be built, and understanding its architecture](#). Threat Dragon's data-flow-diagram capability provides an effective mechanism for doing this. The project team can represent users, applications, APIs, databases, external services, queues, networks and other components, together with the flows of information between them.

Security weaknesses frequently arise at **interfaces and boundaries**, rather than inside individual components. For example, an otherwise secure application may become exposed because:

- an API is accessible from an untrusted network;
- a third-party integration receives more information than necessary;
- authentication is not enforced consistently between services;
- sensitive information crosses a trust boundary without appropriate protection;
- an administrative interface is exposed to ordinary users; or
- a compromised external service is implicitly trusted.

Creating the architecture visually encourages the team to ask these questions early.

Best-practice [threat modelling](#) specifically recommends mapping core components, interfaces, user interfaces, relationships and trust boundaries during threat-discovery workshops. Threat Dragon is a useful tool for this purpose, and could help bridge between architecture design and security analysis.

4. Threat Discovery and Threat Modelling

The most direct Secure by Design application of Threat Dragon is the [threat-modelling activity](#) itself.

A project team can conduct a threat-modelling workshop using the Threat Dragon diagram as the focal point. Architects, developers, security specialists, product owners and other SMEs can work through each component and data flow and ask what could go wrong.

STRIDE is a common threat modelling methodology. It considers:

- **Spoofing** – can an attacker impersonate a user or system?
- **Tampering** – can information or commands be modified?
- **Repudiation** – can actions occur without sufficient evidence for accountability?
- **Information disclosure** – can confidential information be exposed?
- **Denial of service** – can availability be disrupted?
- **Elevation of privilege** – can an attacker obtain privileges beyond those intended?

Threat Dragon supports [STRIDE](#) and can use its rule engine to help generate threats and mitigations from the model. This may help give teams a systematic starting point, rather than identifying individual threats entirely on individual experience or intuition.

However, automated threat generation should be treated as **assistance rather than assurance**. A generated threat is not necessarily relevant, and the absence of a generated threat does not demonstrate that the system is secure. Security specialists must interpret the threats in the context of the actual service, its threat actors, data, business processes and environment.

5. Connecting Threats to Security Controls

Threat modelling is not a standalone activity in Secure by Design; threats can be mapped onto security requirements and controls.

For example, a Threat Dragon model might identify a threat that an attacker could obtain unauthorised access to an administrative API. The project could respond with requirements such as:

- administrative access must use strong authentication;
- privileged access must use phishing-resistant or multi-factor authentication where appropriate;
- administrative interfaces must not be publicly accessible unless explicitly required;
- privileged operations must be logged;
- access must follow least-privilege principles; and
- security monitoring must detect suspicious administrative activity.

So, the lifecycle may look like this:

Architecture → Threat → Risk → Security requirement → Control → Assurance evidence

Threat Dragon is particularly useful for maintaining the first part of this chain, but can be used to support later steps. Threats and their mitigations can be recorded alongside the relevant architectural components, allowing traceability of why a security control was chosen.

6. Supporting Risk Management

Threat Dragon does not replace a project's formal risk-management process, but it provides important evidence for it.

In SecureByDesign, threat modelling is a precursor to security risk assessment. Threat modelling helps identify threat events, vulnerabilities and potential security measures; these can subsequently be considered through the project's formal risk-management process.

Threat Dragon can therefore acts as an important source of technical evidence for the risk assessment, while the formal risk register remains the authoritative mechanism for managing organisational risk.

7. Security Architecture Reviews

Threat Dragon can also support formal security architecture reviews.

A reviewer can use the model to examine:

- trust boundaries;
- authentication and authorisation points;
- sensitive data flows;
- external dependencies;
- privileged operations;
- Internet-facing components;
- third-party services;
- security monitoring boundaries; and
- potential single points of failure.

Because the architecture and threats can be viewed together, the reviewer can ask whether identified risks have corresponding mitigations.

For example, if the model identifies sensitive information crossing an external trust boundary, the review can ask whether encryption, authentication, authorisation, data minimisation and monitoring requirements have been adequately addressed.

The model can therefore provide a structure for security architecture review, rather than relying on an informal walkthrough of architecture diagrams. The results of this review should be documented - whether as acceptance, or risk treatment, or technical actions.

8. Security Testing and Assurance

Threat modelling should also influence security testing.

A threat identified in Threat Dragon should result in an appropriate assurance activity where necessary. For example:

Threat identified	Potential assurance activity
Unauthorised API access	Authentication and authorisation testing
Data disclosure	Data-flow review and penetration testing
Injection attack	SAST, DAST and penetration testing
Privilege escalation	Authorisation testing
Denial of service	Resilience and load testing
Missing audit evidence	Logging and monitoring tests

This approach helps make security testing **risk-driven** rather than simply executing a standard list of tests.

The threat model can also help penetration testers understand the intended architecture and identify high-value attack paths. Conversely, significant findings from penetration testing should be considered against the threat model - to determine whether the model or whether underlying assumptions need updating.

9. Evidence, Governance and Auditability

A major benefit of Threat Dragon is that it can provide tangible evidence of the project's threat-modelling activity.

OWASP describes Threat Dragon as storing threat information alongside the threat-model diagram and supporting PDF reporting. The tool can be deployed as a web application or desktop application.

This makes the model useful as part of a project's security evidence pack.

A mature project should retain:

1. the system context and architecture;
2. the threat model;
3. identified threats;
4. associated mitigations;
5. significant security assumptions;
6. decisions and accepted risks;
7. evidence that the model was reviewed;
8. links to resulting security requirements; and
9. evidence that important mitigations were tested.

Threat models should also be version controlled where practical. Threat Dragon's documentation describes support for storing models through GitHub, GitHub Enterprise, GitLab, Bitbucket and other storage mechanisms in its web application configuration.

Version control is particularly valuable because it demonstrates how the security architecture and threat assessment evolved during the project.

More information

- [Secure by Design Principles \(UK Government Security\)](#)
- [Secure by Design Activities \(UK Government Security\)](#)